welivesecurity.com

Evaluación de vulnerabilidades usando OpenVAS

Mario Micucci

7-9 minutos

Recursos y Herramientas

Te contamos cómo configurar este escáner de uso libre, para identificar vulnerabilidades y corregir las fallas de seguridad que podrían ser explotadas por distintas amenazas.

17 Aug 2023 • , 6 min. read



En la evaluación de debilidades de una infraestructura tecnológica es importante identificar, analizar y evaluar las vulnerabilidades de seguridad, para ejecutar las tareas de remediación necesarias.

OpenVAS (*Open Vulnerability Assessment System*) es un escáner de vulnerabilidades de uso libre que permite identificar y corregir fallas de seguridad, o debilidades en un activo, que pueden ser explotadas por una o más amenazas.

Características de OpenVAS

Se trata de un *framework* con base en servicios y herramientas que puede usarse de forma individual o como parte del conjunto de herramientas de seguridad incluidas en OSSIM (*Open Source Security Information Management*).

Distribuciones como Kali Linux ya cuentan con esta herramienta instalada de forma predefinida, aunque en el caso de Kali Linux 2023, la misma hay terminar de instalarla y configurarla para poder emplearse a través de dos clientes, desde línea de comandos (OpenVAS CLI), o una interfaz web (*Greenbone Security Assistant*).

Una vez instalada en el sistema, también se puede usar desde Metasploit, el framework para la explotación de vulnerabilidades.

A través de las interfaces se interactúa con dos servicios: OpenVAS Manager y OpenVAS *Scanner.*

El gestor es el servicio que lleva a cabo tareas como el filtrado o clasificación de los resultados del análisis, control de las bases de datos que contienen la configuración o los resultados de la exploración y la administración de los usuarios, incluyendo grupos y roles.

Por su lado, el escáner ejecuta las denominadas NVT (*Network Vulnerability Tests*), es decir, las pruebas de vulnerabilidades de red, conformadas por rutinas que comprueban la presencia de un problema de seguridad específico conocido o potencial en los sistemas.

Las NVT se agrupan en familias de pruebas similares, por lo que la selección de las familias y/o NVT individuales es parte de la configuración de escaneo.

El proyecto OpenVAS mantiene una colección de NVT (OpenVAS NVT Feed) que crece constantemente y que actualiza los registros semanalmente. Los equipos instalados con OpenVAS se sincronizan con los servidores para actualizar las pruebas de vulnerabilidades.

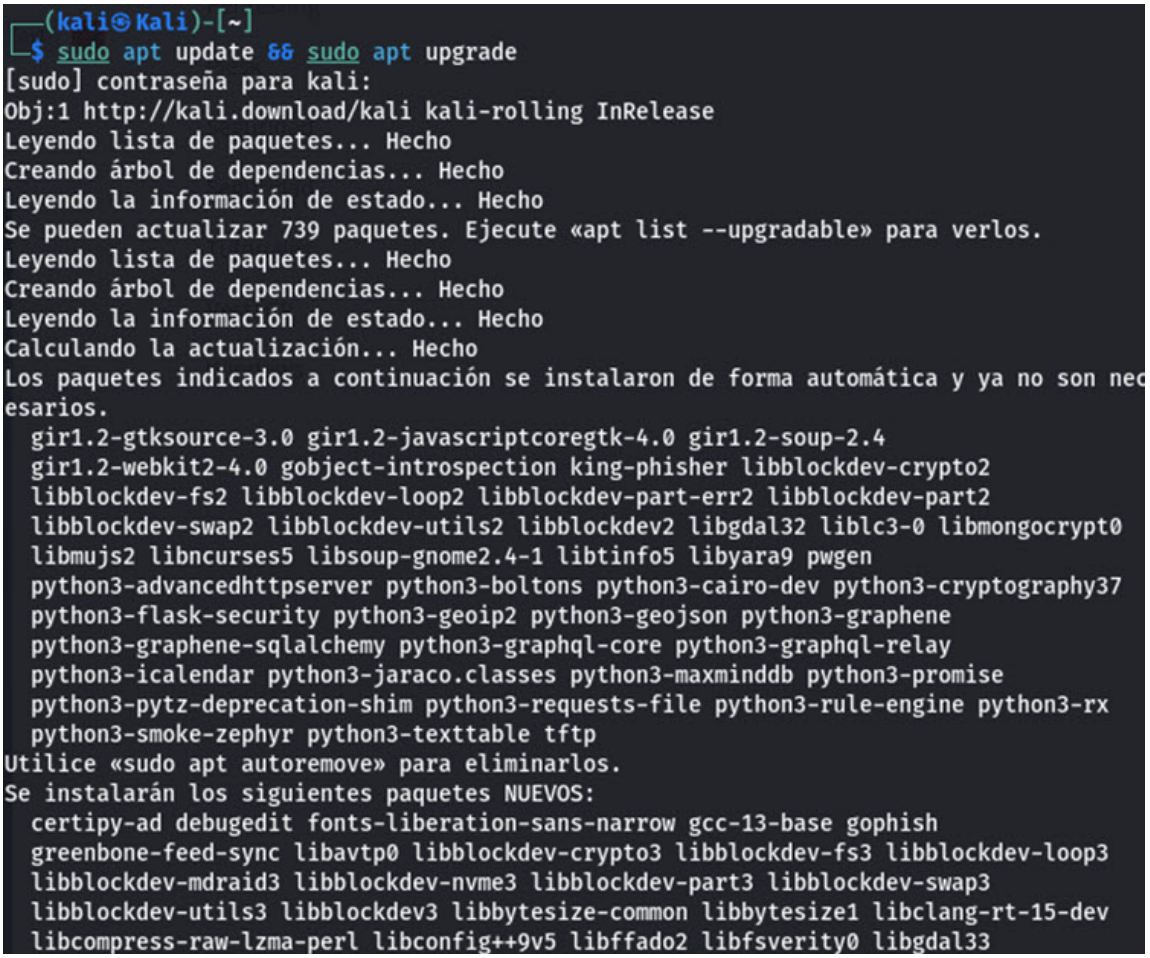
Instalación y configuración de OpenVAS

En este ejemplo vamos a conocer la manera más rápida y sencilla de utilizar OpenVAS, a través de la interfaz web y con el sistema operativo Kali Linux que cuenta con esta herramienta de forma preinstalada.

En nuestro caso utilizaremos la versión 2023 de Kali Linux, y es importante destacar que, si bien la misma se encuentra preinstalada, hay que terminar su instalación y configuración

En primera instancia actualizaremos nuestro sistema utilizando los siguientes comandos

sudo apt update && sudo apt upgrade

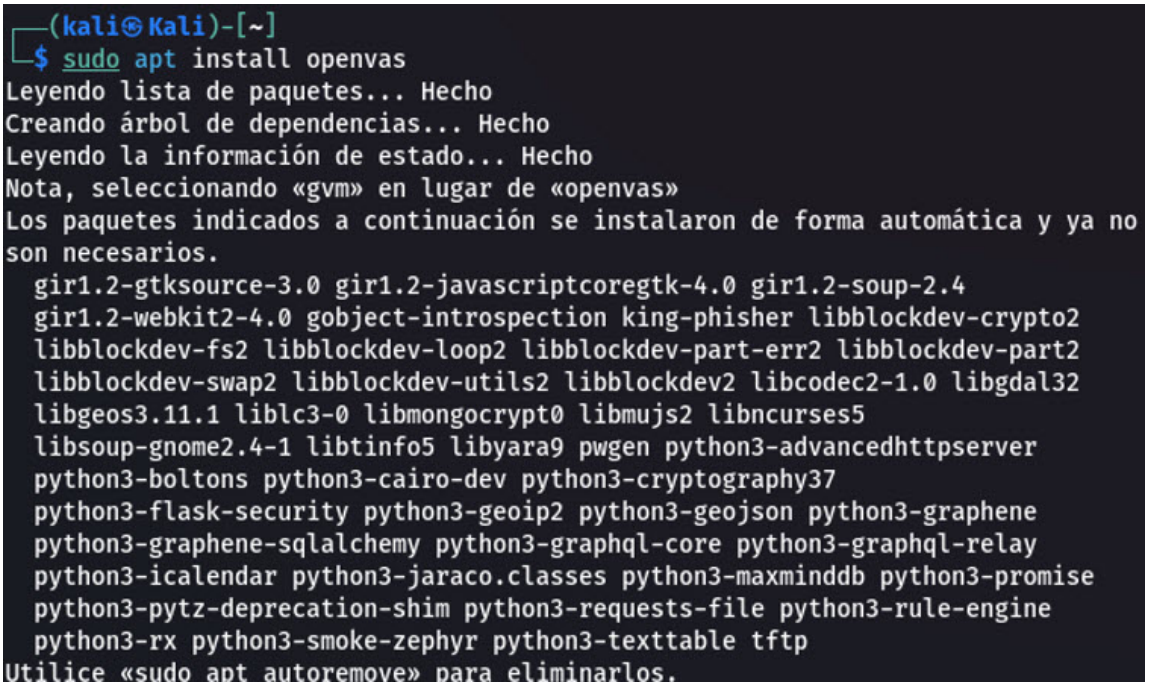


Nota: Según qué tan vieja sea tu versión de Kali necesitarás también ejecutar el siguiente comando

sudo apt dist-upgrade

Luego instalaremos OpenVas mediante el siguiente comando

sudo apt install openvas



```
Se instalarán los siguientes paquetes adicionales:
  greenbone-security-assistant gsad gvm-tools libmicrohttpd12
Se instalarán los siguientes paquetes NUEVOS:
  greenbone-security-assistant gsad gvm gvm-tools libmicrohttpd12
0 actualizados, 5 nuevos se instalarán, 0 para eliminar y 0 no actualizados.
Se necesita descargar 5.078 kB de archivos.
Se utilizarán 20,6 MB de espacio de disco adicional después de esta operación.
¿Desea continuar? [S/n]
```

Más tarde instalaremos los *feeds* GVM mediante el siguiente comando

sudo apt install gvm -y

```
┌──(kali㉿Kali)-[~]
└─$ sudo apt install gvm -y
[sudo] contraseña para kali:
Leyendo lista de paquetes... Hecho
Creando árbol de dependencias... Hecho
Leyendo la información de estado... Hecho
Los paquetes indicados a continuación se instalaron de forma automática y ya no son nec
esarios.
  gir1.2-gtksource-3.0 gir1.2-javascriptcoregtk-4.0 gir1.2-soup-2.4
  gir1.2-webkit2-4.0 gobject-introspection king-phisher libblockdev-crypto2
  libblockdev-fs2 libblockdev-loop2 libblockdev-part-err2 libblockdev-part2
  libblockdev-swap2 libblockdev-utils2 libblockdev2 libgdal32 liblc3-0 libmongocrypt0
  libmujs2 libncurses5 libsoup-gnome2.4-1 libtinfo5 libyara9 pwgen
  python3-advancedhttpserver python3-boltons python3-cairo-dev python3-cryptography37
  python3-flask-security python3-geoip2 python3-geojson python3-graphene
  python3-graphene-sqlalchemy python3-graphql-core python3-graphql-relay
  python3-icalendar python3-jaraco.classes python3-maxminddb python3-promise
  python3-pytz-deprecation-shim python3-requests-file python3-rule-engine python3-rx
  python3-smoke-zephyr python3-texttable tftp
Utilice «sudo apt autoremove» para eliminarlos.
Se instalarán los siguientes paquetes adicionales:
  greenbone-security-assistant gsad gvm-tools libmicrohttpd12
Se instalarán los siguientes paquetes NUEVOS:
  greenbone-security-assistant gsad gvm gvm-tools libmicrohttpd12
0 actualizados, 5 nuevos se instalarán, 0 para eliminar y 0 no actualizados.
Se necesita descargar 5.078 kB de archivos.
Se utilizarán 20,6 MB de espacio de disco adicional después de esta operación.
Des:1 http://kali.download/kali kali-rolling/non-free amd64 greenbone-security-assistan
t all 22.5.0-0kali1 [4.668 kB]
Des:2 http://kali.download/kali kali-rolling/main amd64 libmicrohttpd12 amd64 0.9.77-3
```

sudo gvm-setup

```
┌──(kali㉿Kali)-[~]
└─$ sudo gvm-setup

[>] Starting PostgreSQL service

[>] Creating GVM's certificate files

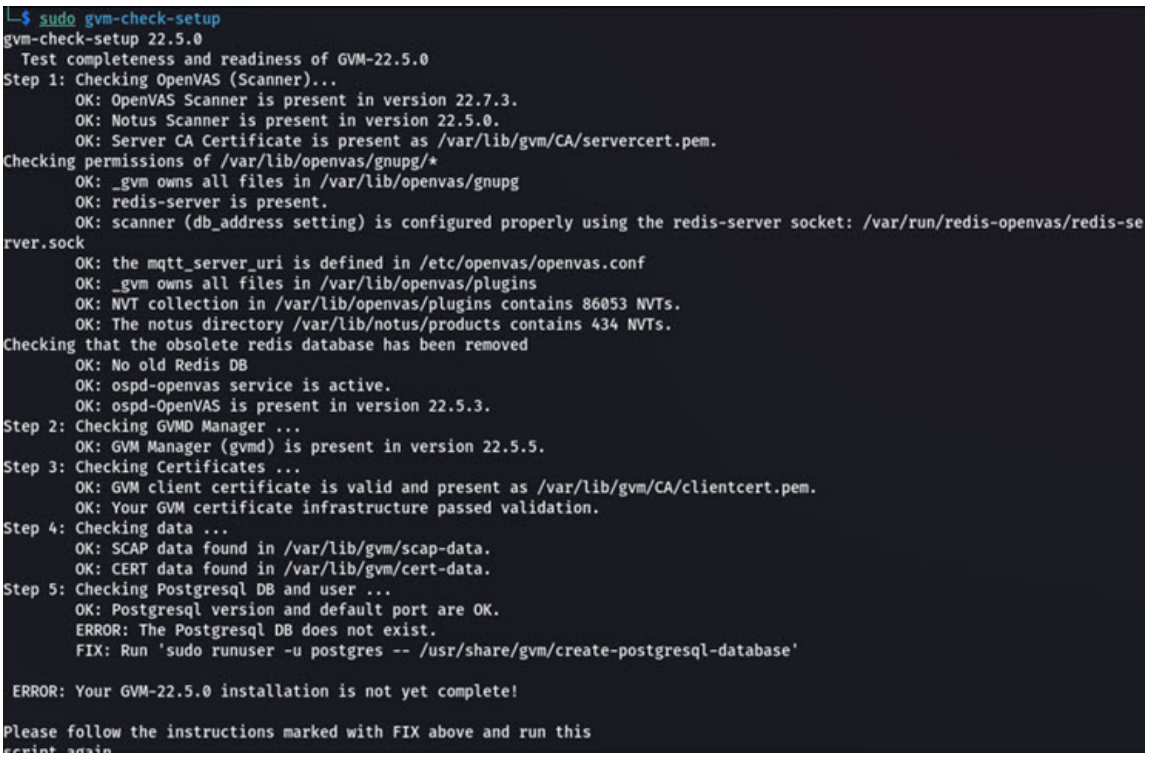
[>] Creating PostgreSQL database
could not change directory to "/home/kali": Permiso denegado
WARNING:  database "postgres" has a collation version mismatch
DETALLE:  The database was created using collation version 2.36, but the operating syst
em provides version 2.37.
SUGERENCIA:  Rebuild all objects in this database that use the default collation and ru
n ALTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right
 library version.

[*] Creating database user
could not change directory to "/home/kali": Permiso denegado
WARNING:  database "postgres" has a collation version mismatch
DETALLE:  The database was created using collation version 2.36, but the operating syst
em provides version 2.37.
```



Es importante que sepas que en este punto pueden aparecer varios problemas, tal como vemos en las capturas donde se muestran algunos mensajes de error que habrá que ir reparando

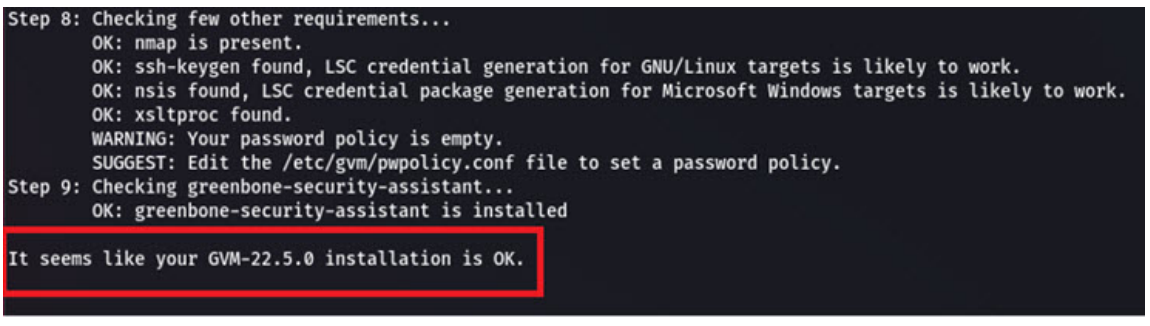
Ejecutando sudo gvm-check-setup podemos validar si existieron fallos en la instalación como pasa en este ejemplo:



Esta puede ser una parte tediosa, ya que tendrás que ir haciendo *troubleshooting* de los errores que puedan llegar a aparecer. En la mayoría de los casos los problemas para correr OpenVas en Kali Linux 2023 pueden estar relacionados con la configuración de la base de datos.

Si este es tu caso, te recomendamos busques info de los errores que obtengas en el foro de OpenVas donde hay detalles de cómo *fixear* cada problema

En este ejemplo, logramos *fixear* todos los errores para la ejecución de sudo gvm-check-setup y asegurarnos de que no hay errores en la instalación.

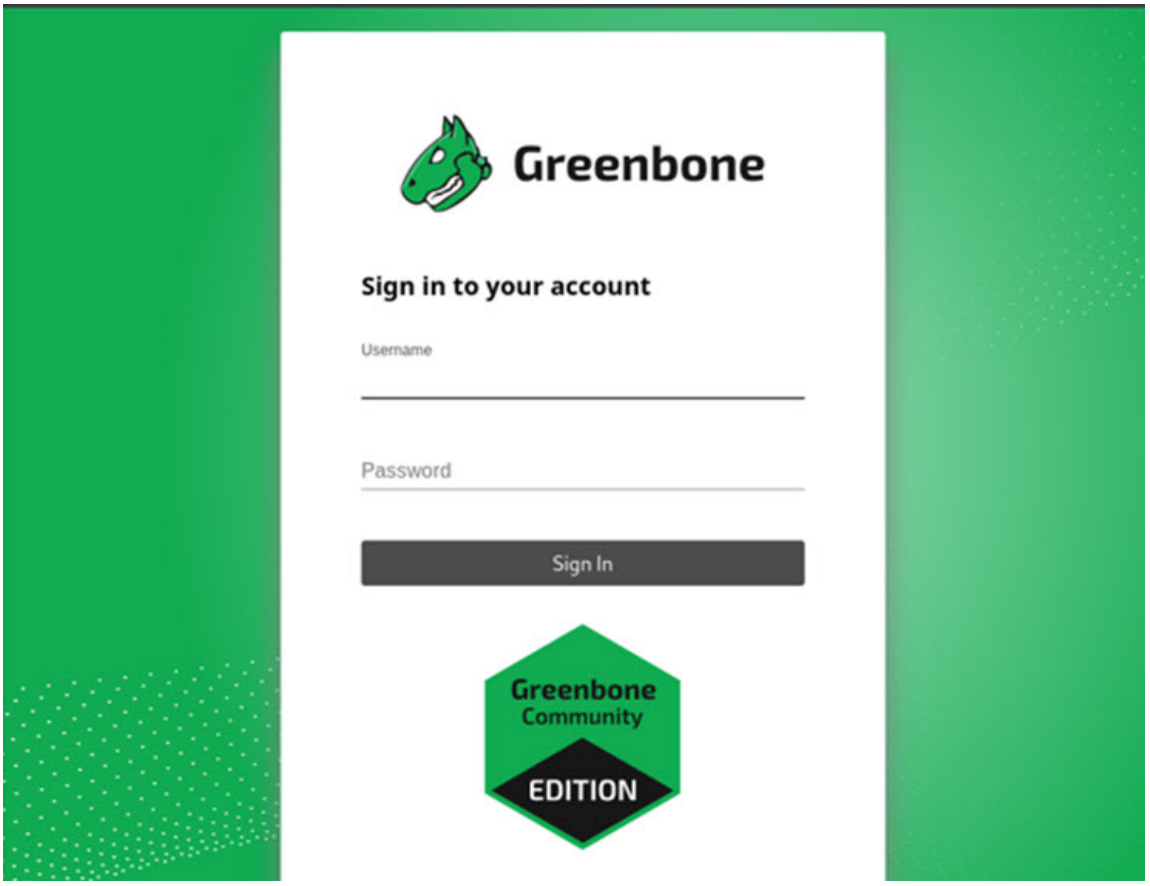


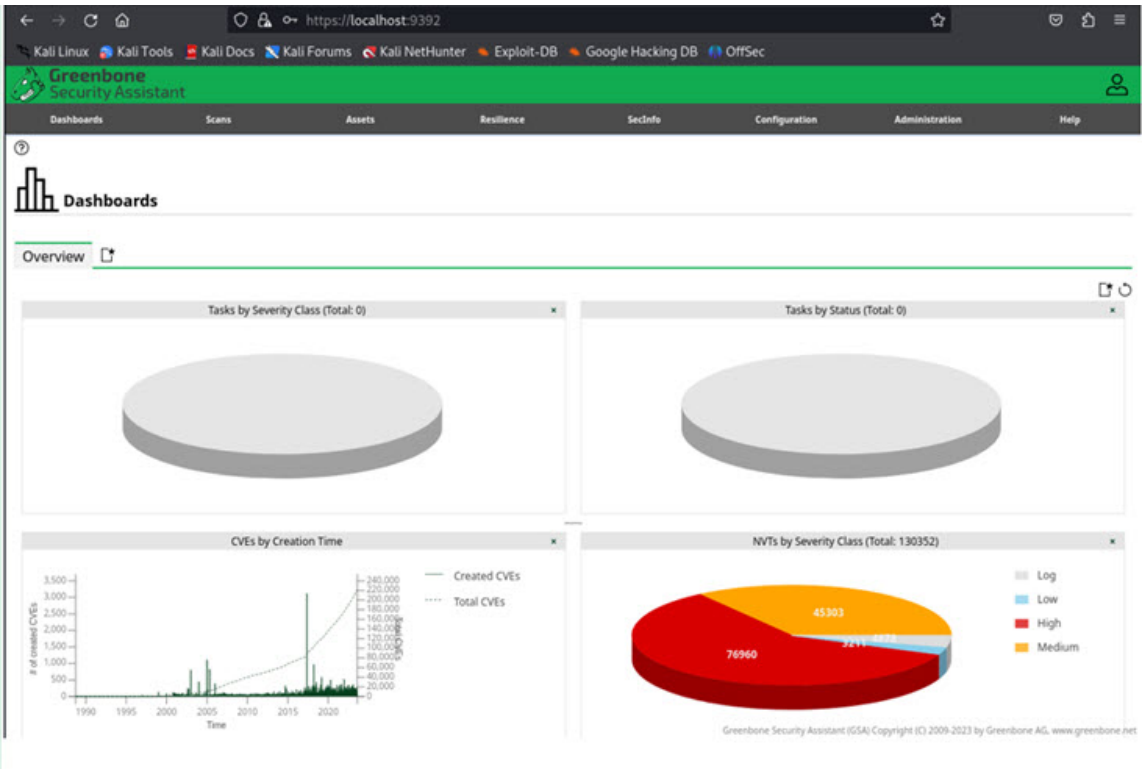
Uso básico de OpenVAS

Una vez que el script ha concluido con éxito la configuración, se comienza a utilizar el escáner desde la siguiente URL:

https://localhost:9392

En este momento, solo existe la cuenta de acceso inicial con el usuario *admin* y la contraseña generada durante la configuración, o bien el usuario y contraseña que elegimos cuando generamos el proceso de instalación:



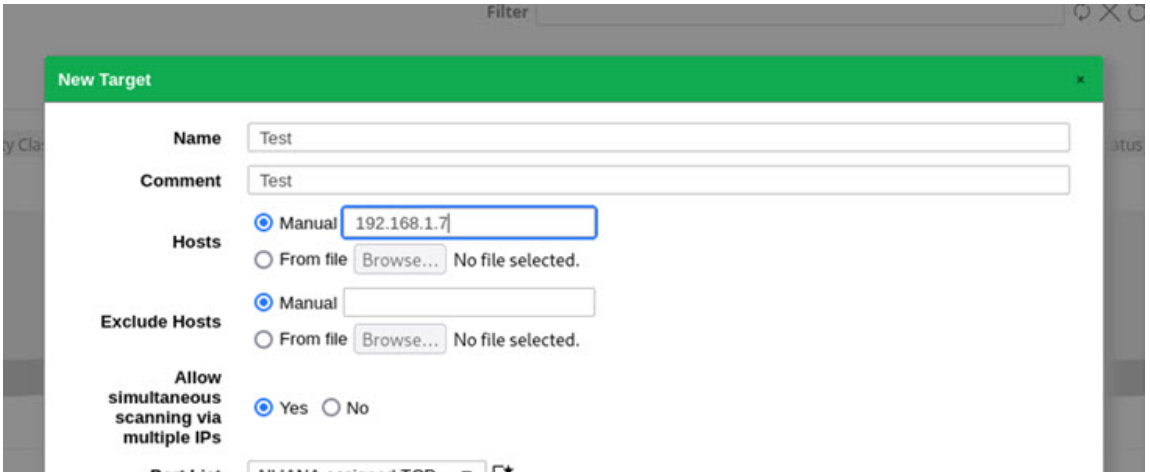


Luego de iniciar la sesión de trabajo, se tienen las siguientes opciones para configurar e iniciar el gestor y escáner de OpenVAS:

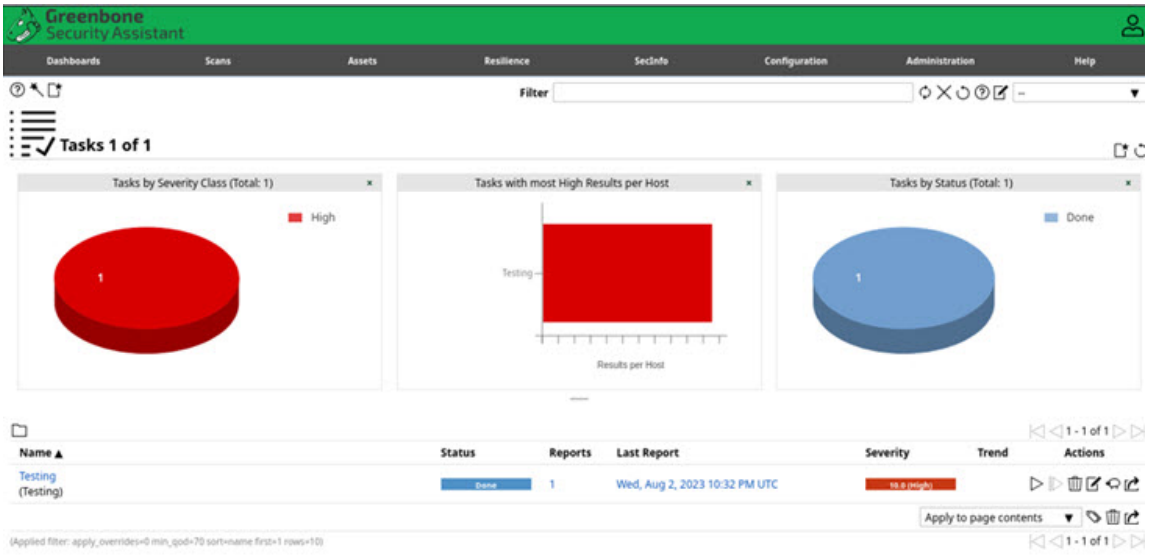
- Scans: La gestión del escáner permite crear nuevas tareas de exploración, modificar aquellas que se hayan creado previamente, revisar las notas (comentarios asociados con un NVT que aparecen en los informes), o invalidaciones (reglas para cambiar amenazas de elementos dentro de uno o varios informes, especialmente utilizadas cuando se presentan falsos positivos).
- Assets: En la pestaña de gestión de activos se enlistan los hosts que han sido analizados junto con el número de vulnerabilidades identificadas.
- Configuration: La tercera pestaña permite configurar los objetivos, asignar credenciales de acceso para revisiones de seguridad locales, configurar el escaneo (selección de NVT, parámetros generales y específicos para el servidor de exploración), programar escaneos, configurar la generación de los informes, entre otras opciones.
- Administration: Permite gestionar los usuarios del escáner, la configuración para la sincronización de NVT Feed y muestra las opciones de configuración de OpenVAS.
- Help: Ofrece información de ayuda para todos los elementos de la interfaz web.

El inicio rápido se realiza desde la pestaña *Scans*, a través de configurar un objetivo o un conjunto de sistemas (hosts) a analizar. Los sistemas se pueden identificar a través de sus direcciones IP, nombres de host o por su notación de red CIDR (Classless Inter-Domain Routing):





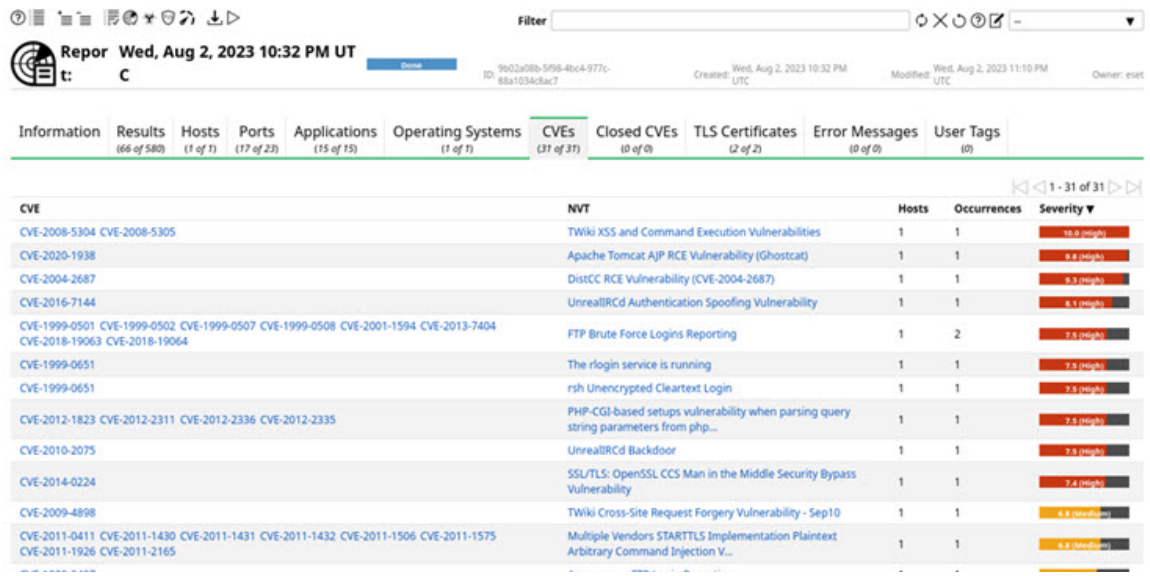




Una vez hecha la configuración del objetivo, daremos a la opción *Save* y luego *Run/Play* para echar a correr el escaneo y la ejecución del análisis y evaluación. La tarea se conforma por un objetivo y una configuración de escaneo. La ejecución significa iniciar el escaneo y como resultado se obtiene un informe con los resultados.

Con la conclusión del escáner, se obtienen los resultados de las vulnerabilidades priorizadas de acuerdo al impacto sobre los sistemas (alto, medio o bajo) y la cantidad de las mismas para cada categoría.

En el informe se muestra con mayor detalle la vulnerabilidad identificada y evaluada. Incluye la prueba de red utilizada (NVT), un resumen del hallazgo, así como una posible solución a la falla.





Idealmente, los escáneres deben usarse como una medida que permita complementar las prácticas de seguridad ya existentes dentro de una organización, y con base en los resultados, se debe generar un plan de remediación, que debe tener seguimiento para corregir cualquier vulnerabilidad.

De esta manera, se puede llevar a cabo una evaluación de seguridad a los sistemas de una organización en busca de aumentar la seguridad en los mismos. Adicional a esta actividad, existen otras preocupaciones, por lo que es necesario complementarla con soluciones de seguridad, como aquellas contra códigos maliciosos, *firewalls*, herramientas de detección de intrusos y buenas políticas de seguridad contribuyen a la protección de los activos (incluida la información) y a la conjunción de distintos enfoques de seguridad.